Politique d'effacement & Droits des personnes — Lidl Collect

> Référence : RGPD Art. 17 (droit à l'effacement), Art. 20 (droit à la portabilité), Art. 12 (délais de réponse) Base de données : PostgreSQL via Supabase — région Frankfurt (Union européenne) — aucun transfert hors de l'Union européenne Dernière mise à jour : 2026-04-16

1. CARTOGRAPHIE DES DONNÉES PERSONNELLES PAR EMPLACEMENT

Tables supprimées physiquement à la suppression de compte

TABLE	DONNÉES PERSONNELLES	BASE LÉGALE DE SUPPRESSION
`Client`	nom, prénom, email, mot de passe hashé, téléphone, adresse	Art. 17 RGPD — aucune obligation de conservation
`Client_Account`	is_verified, is_active, last_login_at	Art. 17 RGPD — aucune obligation de conservation
`Client_History`	loyalty_points, loyalty_status	Art. 17 RGPD — aucune obligation de conservation
`Cart`	client_id	Art. 17 RGPD — aucune obligation de conservation
`CartItem`	via cart_id (cascade)	Art. 17 RGPD — aucune obligation de conservation
`Notification`	client_id	Art. 17 RGPD — aucune obligation de conservation

Tables pseudonymisées (conservation légale obligatoire)

> **Note juridique importante** — La pseudonymisation est une mesure de réduction du risque (Art. 32 RGPD), **pas un effacement** au sens de l'Art. 17. Les données ci-dessous ne sont pas effacées parce qu'une exception à l'Art. 17.3 s'applique — la pseudonymisation vient en complément pour minimiser le risque résiduel. L'exception Art. 17.3 applicable est identifiée colonne par colonne.

TABLE	CHAMP PSEUDONYMISÉ	EXCEPTION ART. 17.3 APPLICABLE	BASE LÉGALE DE CONSERVATION	DURÉE
`Order`	client_id → token anonyme	Art. 17.3.b — obligation légale (Art. L123-22 Code de commerce)	Art. 6.1.c — Obligation légale comptable	10 ans
`OrderItem`	via order_id	Art. 17.3.b — même base	Art. 6.1.c	10 ans
`Payment`	via order_id	Art. 17.3.b — même base + directive TVA 2006/112/CE	Art. 6.1.c	10 ans
`SubstitutionProposal`	via order_item_id	Art. 17.3.b — même base	Art. 6.1.c	10 ans
`AuditLog`	actor_id → token anonyme	Art. 17.3.e — constatation, exercice ou défense de droits en justice	Art. 6.1.f — intérêt légitime (sécurité Art. 32)	1 an
`Consent`	client_id → token anonyme	Art. 17.3.e — preuve de conformité réglementaire (accountability Art. 5.2)	Art. 6.1.f — intérêt légitime	Durée indéterminée
`Schedule`	preparer_id → token anonyme	Art. 17.3.b — obligation légale (Art. L3243-4 Code du travail)	Art. 6.1.c	5 ans après départ
`Performance`	preparer_id → token anonyme	Art. 17.3.b — même base	Art. 6.1.c	5 ans après départ

Emplacements hors base de données

EMPLACEMENT	DONNÉES PERSONNELLES	DURÉE LÉGALE	PROCÉDURE À LA DEMANDE INDIVIDUELLE
Logs Nginx	ip_address, user-agent	1 an — Art. L34-1	Non modifiable individuellement — durée légale fixe
Logs applicatifs	Métadonnées de requêtes — aucune donnée personnelle en clair	1 an — Art. L34-1	Non modifiable individuellement
Sauvegardes Supabase	Copie complète de la base	7 jours	Risque résiduel documenté — voir section 6

2. RÈGLE DE PSEUDONYMISATION

Principe retenu

La pseudonymisation substitue l'identifiant direct de la personne (son `client_id` ou `preparer_id`) par un token calculé à l'aide d'un algorithme cryptographique à clé secrète. Ce token est déterministe : le même identifiant produit toujours le même token, assurant la cohérence entre les tables pseudonymisées.

La clé secrète est stockée en dehors de la base de données (variable d'environnement isolée). La ré-identification est impossible sans accès à cette clé. Un mécanisme de rotation de la clé est prévu pour limiter l'impact d'une compromission éventuelle.

Qualification juridique importante

> Cette opération est une **pseudonymisation** au sens du considérant 26 du RGPD — **pas une anonymisation**. Tant que la clé secrète existe, la ré-identification reste théoriquement possible par quiconque la détient. Les données pseudonymisées restent des données personnelles soumises au RGPD. La pseudonymisation est une mesure de sécurité qui réduit le risque sans l'éliminer.

3. PROCÉDURE DE TRAITEMENT D'UNE DEMANDE D'EFFACEMENT (ART. 17)

Délai légal : 30 jours (Art. 12 RGPD)

```
Étape 1 — Réception et vérification d'identité
  → Via interface authentifiée : session valide = identité vérifiée
  → Via email hors-session : code de confirmation envoyé sur l'email du compte
  → Ne jamais traiter une demande sans vérification — risque de suppression forcée par un
  → Enregistrement dans l'AuditLog (DELETION_REQUESTED)

Étape 2 — Vérification des obligations légales
  - Le compte a-t-il des commandes validées ?
      → Oui : pseudonymisation de Order, OrderItem, Payment, SubstitutionProposal
      → Non : suppression physique uniquement
  - Le compte a-t-il des entrées dans l'AuditLog ?
      → Oui : pseudonymisation de actor_id
  - Le compte a-t-il des enregistrements Consent ?
      → Oui : pseudonymisation de client_id (jamais suppression)

Étape 3 — Exécution (transaction atomique)
  La suppression est exécutée dans une transaction atomique garantissant l'intégrité
  des données. En cas d'échec partiel, l'ensemble de l'opération est annulé et une
  alerte est générée — une suppression partielle est pire qu'une absence de suppression.
  → Pseudonymisation des identifiants dans les tables sous obligation légale
  → Suppression physique des tables sans obligation légale
  → Entrée AuditLog (DELETION_COMPLETED) avec identifiant pseudonymisé

Étape 4 — Confirmation à l'utilisateur
  → Email de confirmation sous 30 jours (Art. 12 RGPD)
  → Contenu : liste de ce qui est supprimé, liste de ce qui est conservé + base légale
```

4. ENDPOINTS — FONCTIONS DISPONIBLES

DELETE /api/user/me — Suppression de compte

Authentification requise : session valide (rôle CLIENT)

La suppression est exécutée dans une transaction atomique : toutes les opérations de pseudonymisation et de suppression physique sont réalisées en un seul bloc indivisible. En cas d'erreur sur l'une des étapes, aucune modification n'est persistée — l'état de la base reste cohérent. L'échec est enregistré dans l'AuditLog sans donnée personnelle dans le contexte d'erreur.

Réponse succès : confirmation + email envoyé à l'utilisateur **Réponse échec :** notification d'échec + retry manuel déclenché

GET /api/user/export — Export des données personnelles

Authentification requise : session valide (rôle CLIENT)

DISTINCTION ART. 15 VS ART. 20

	ART. 15 — DROIT D'ACCÈS	ART. 20 — DROIT À LA PORTABILITÉ
Périmètre	Toutes les données détenues, y compris déduites	Données fournies activement par l'utilisateur
Format	Tout format lisible	Format structuré, lisible par machine
Cet endpoint	Couverture partielle	Couverture complète

> Cet endpoint couvre principalement l'**Art. 20**. Pour une réponse complète à l'Art. 15 (incluant logs, métadonnées, données déduites), une procédure manuelle complémentaire est nécessaire — à documenter dans la politique de confidentialité.

Format de réponse : JSON — données du compte, historique de commandes, consentements enregistrés.

5. TEMPLATE DE RÉPONSE À L'UTILISATEUR

```
Objet : Confirmation de suppression de votre compte Lidl Collect

Bonjour,

Nous avons bien reçu et traité votre demande de suppression de compte.

Ce qui a été supprimé :
- Vos informations personnelles (nom, prénom, email, téléphone, adresse)
- Votre historique de connexion et de fidélité
- Votre panier et vos préférences

Ce qui est conservé (obligation légale) :
- Vos historiques de commandes sous forme pseudonymisée — 10 ans
  (Art. L123-22 du Code de commerce)
- Les traces de sécurité pseudonymisées — 1 an
  (Art. 6.1.f RGPD — démonstration de conformité)
- Les enregistrements de consentement pseudonymisés — durée indéterminée
  (preuve légale de consentement)

Note sur les sauvegardes :
Vos données peuvent subsister dans nos sauvegardes chiffrées
pendant une durée maximale de sept jours après suppression.
Ces sauvegardes sont chiffrées et hébergées en Europe (Frankfurt).

Votre identité directe n'est plus associée à ces données conservées ; elles sont
pseudonymisées et ne permettent pas votre identification sans recours à une clé
de correspondance détenue par le responsable du traitement.

Pour toute question, vous pouvez contacter la CNIL :
https://www.cnil.fr/fr/plaintes

Cordialement,
L'équipe Lidl Collect
```

6. POLITIQUE DE TRAITEMENT DES SAUVEGARDES SUPABASE

- Sauvegardes chiffrées AES-256, hébergées région Frankfurt (Union européenne)
- **Stratégie de sauvegarde en production :** PITR 7 jours. Restauration à la seconde près via les fichiers WAL enregistrés en continu vers AWS S3, même région Frankfurt.
- Supabase ne permet pas la suppression manuelle d'un enregistrement dans les sauvegardes.
- **Risque résiduel documenté et accepté :** une donnée supprimée de la base principale peut subsister dans les sauvegardes pendant toute la durée de rétention souscrite.

Conditions de tolérance du risque résiduel (RGPD)

Le risque résiduel lié aux sauvegardes est légalement toléré sous trois conditions cumulatives :

1. La durée de rétention des sauvegardes est documentée et raisonnable (sept jours).
2. Ces sauvegardes sont sécurisées et réservées à la seule reprise sur incident. Aucun accès opérationnel aux données pseudonymisées n'est autorisé depuis les sauvegardes.
3. En cas de restauration depuis un point antérieur à une ou plusieurs demandes d'effacement au titre de l'article 17, toutes les suppressions et pseudonymisations réalisées entre ce point et la date de restauration doivent être ré-appliquées manuellement par l'équipe avant toute remise en service.

> **Point d'attention opérationnel :** une restauration d'urgence peut techniquement réintroduire les données d'un compte supprimé. La procédure de restauration doit systématiquement inclure une consultation de l'AuditLog afin d'identifier les comptes supprimés dans la fenêtre temporelle concernée.

- **Mesure compensatoire :** l'utilisateur est informé du risque résiduel de sept jours dans l'email de confirmation (voir section 5).

7. AUDITLOG — ACTIONS TRACÉES ET DURÉE DE CONSERVATION

ACTION	DÉCLENCHEUR	DONNÉES LOGGÉES
`DELETION_REQUESTED`	Réception de la demande	identifiant (valide à ce stade), timestamp
`DELETION_COMPLETED`	Fin de transaction réussie	identifiant (pseudonymisé), timestamp
`DELETION_FAILED`	Annulation de transaction	identifiant (pseudonymisé), étape échouée, timestamp — aucune donnée personnelle dans le contexte d'erreur
`EXPORT_REQUESTED`	Appel export données	identifiant (valide), timestamp

Durée de conservation des AuditLogs : 1 an Base légale : Art. 6.1.f RGPD — intérêt légitime (sécurité du traitement, Art. 32 RGPD) + Art. L34-1 (obligation sectorielle de conservation des données de connexion).

8. DROITS DES PERSONNES — TABLEAU COMPLET

DROIT	ARTICLE	ENDPOINT / PROCÉDURE	STATUT
Droit d'accès	Art. 15	`GET /api/user/me` (données directes) + procédure manuelle (logs)	À implémenter
Droit de rectification	Art. 16	`PATCH /api/user/me`	À implémenter
Droit à l'effacement	Art. 17	`DELETE /api/user/me`	Spécifié — section 3
Droit à la limitation	Art. 18	Flag `processing_restricted` en base — gel des traitements pendant contestation	À implémenter
Droit à la portabilité	Art. 20	`GET /api/user/export`	Spécifié — section 4
Droit d'opposition	Art. 21	Applicable aux traitements fondés sur Art. 6.1.f : AuditLog (T08), performance préparateurs (T12). Réception de l'opposition → vérification du motif → suspension du traitement concerné → réponse sous 1 mois (Art. 12). Aucune opposition ne peut être opposée aux traitements fondés sur Art. 6.1.b ou 6.1.c.	⚠️ À implémenter
Droit de réclamation CNIL	Art. 77	Information à inclure dans la politique de confidentialité : https://www.cnil.fr/fr/plaintes	À mentionner